

TryHackMe - Containment Writeup

Category: Blue Team / Incident Response / AI Security | **Difficulty:** Medium | **Room:** Containment |

Date: September 2026

Scenario: You are a Security Analyst at West Tech, a classified defence & R&D contractor. A ransomware incident has been detected on senior researcher Oliver Deer's workstation. Your mission: investigate the breach, trace the attacker's actions, recover stolen data, and contain the threat.

1. Initial Access & Reconnaissance

1.1 SSH into the Workstation

SSH credentials were provided to access the affected employee's workstation:

```
ssh o.deer@10.49.130.159
Password: TryHackMe!
```

1.2 Examine the Desktop

A ransom/pwned note was found on the desktop:

```
ls -la ~/Desktop/
# File: pwned.txt
```

```
cat ~/Desktop/pwned.txt
> Name: Oliver Deer
> DOB: 1990-04-11
> Email: o.deer@west-tech.io
> Address: 41 Falkner Lane, Denver, CO
> Phone: (720) 555-0173
> Employee ID: WT-DEV-88112
> Salary:
```

The attacker exfiltrated personal employee data. This is evidence of a data breach.

1.3 Key Files & Artifacts Discovered

Location	File	Purpose
~/Desktop/	pwned.txt	Exfiltrated personal employee data
~/Downloads/	invoice_payload.scr	Malicious dropper disguised as an invoice
~/	westtech_projects_encrypted.zip	Encrypted archive of stolen project data
~/Mail/	2025-06-17_invoice_required_review.eml	Phishing email delivering the payload
~/Documents/ pcap_dumps/	session_4444_dump.pcap	Captured exfiltration traffic (port 4444)
~/alarms/soc_alarms/ 2025-06-17/	exfiltration_detected_1.log	SOC alert: unauthorized nc connection

2. Phishing Analysis & Initial Compromise

2.1 The Phishing Email

The attack vector was a phishing email delivered on June 17, 2025:

```
Subject: INVOICE - URGENT REVIEW REQUIRED
From: billing@westteck-payments.com    <-- note the typo "westteck"
To: o.deer@westtech.internal
Date: 2025-06-17

Dear O.Deer,

Please review the attached invoice for last quarter's procurement activity.

Failure to respond within 24 hours will result in service suspension.

Attachment: invoice_payload.scr
```

Key indicators of phishing:

- Spoofed sender domain: westteck-payments.com (missing 'h' in "westtech")
- Urgency/social engineering: "24 hours or service suspension"

- Malicious attachment: `.scr` file (Windows screensaver extension, often used for malware delivery)

2.2 The Malicious Payload

The `invoice_payload.scr` is an ASCII bash script (not a real screensaver):

```
cat ~/Downloads/invoice_payload.scr
cat << 'EOF' | sudo tee /home/o.deer/Downloads/invoice_payload.scr > /dev/null
```

This script would overwrite itself after execution - a classic anti-forensics technique to cover tracks. When Oliver Deer opened the attachment, it executed and established persistence.

3. Attack Timeline from SOC Alarms

3.1 Pre-Attack Activity (June 15-16)

Date	Alarm Type	Description
2025-06-15	PortScan (x4)	Reconnaissance - network scanning
2025-06-15	MalwarePing (x2)	Malware C2 beaconing detected
2025-06-15	FailedAuth (x3)	Brute force / credential stuffing attempts
2025-06-15	USBInsertion	USB device connected (potential vector or staging)
2025-06-16	FailedAuth (x2)	Continued credential attacks
2025-06-16	PortScan (x2)	Internal network recon continues
2025-06-16	USBInsertion (x5)	Multiple USB insertions - data staging
2025-06-16	MalwarePing	Continued C2 communication

3.2 Attack Day (June 17)

Date	Alarm Type	Description
2025-06-17	FailedAuth (x2)	Final credential attempts
2025-06-17	PortScan (x3)	Lateral movement reconnaissance

2025-06-17	USBInsertion (x4)	Data staging via USB
CRITICAL: exfiltration_detected_1.log		
2025-06-17	Data Exfiltration	Unauthorized outbound connection on port 4444 via <code>/bin/nc</code> (netcat) to IP 144.76.12.34 . 181,923 bytes exfiltrated.

3.3 Post-Attack (June 18)

Continued MalwarePing and FailedAuth alarms indicate the attacker maintained persistence. The encrypted zip file was created, containing all stolen project data.

4. Network Forensics

4.1 Suspicious PCAP - Session 4444

The file `session_4444_dump.pcap` (2,262 bytes vs. normal 198 bytes) captured the exfiltration traffic on June 17:

```
strings ~/Documents/pcap_dumps/2025-06-17/session_4444_dump.pcap
EDAC::GARBAGE::FORMAT<<<OBF>>> v3.4
t: o.de[@@v
```

The hex dump reveals a TCP connection from the workstation to the external C2 server, matching the exfiltration alert on port 4444.

5. Decrypting the Stolen Data

5.1 Extracting the Encrypted Archive

The file `westtech_projects_encrypted.zip` in the home directory contained all stolen project data. Based on evidence gathered during the investigation, the password was identified as:

```
unzip -P "westtechvictim1" ~/westtech_projects_encrypted.zip -d /tmp/westtech
```

5.2 Recovered Project Files

File	Content
------	---------

vault_tek_collab_agenda.doc	Vault-Tek & West Tech strategic collaboration meeting agenda
internal_security_incident_233.json	Internal breach report - unauthorized biometric vault access
email_export_april2025.eml	Internal email about Vault-Tek integration contract risks
project_chimera_specs.txt	Bio-weapon hybrid platform specs (Project Chimera)
prototype_plasma_launcher_test_logs.log	Plasma weapon prototype test logs
fusion_cell_mk3_blueprints.pdf	Fusion cell blueprints
thm_flags.txt	500 base64-encoded candidate flags
thm_flags_guide.txt	Instructions for finding the true flag

6. Finding the True Flag

6.1 The Challenge

The `thm_flags.txt` contains 500 base64-encoded strings. Each decodes to a flag in the format `thm{n1,n2,n3,n4,n5}` where each number is between 10-99. The rule from the guide:

The true flag is the only one with exactly 3 prime numbers in its contents.

6.2 Python Script to Find the Flag

```
import base64

def is_prime(n):
    if n < 2: return False
    if n == 2: return True
    if n % 2 == 0: return False
    for i in range(3, int(n**0.5) + 1, 2):
        if n % i == 0: return False
    return True

with open("thm_flags.txt") as f:
    lines = f.read().strip().split("\n")

for line in lines:
    decoded = base64.b64decode(line.strip()).decode()
    nums = [int(x) for x in decoded.replace("thm{","").replace("}", "").split(",")]
```

```
prime_count = sum(1 for n in nums if is_prime(n))
if prime_count == 3:
    print(f"TRUE FLAG: {decoded}")
    print(f"Primes: {[n for n in nums if is_prime(n)]}")
    break
```

6.3 Result

```
TRUE FLAG: thm{23,82,20,17,53}
Primes: [23, 17, 53]
```

Verification:

- 23 — Prime
- $82 = 2 \times 41$ — Not prime
- $20 = 2 \times 2 \times 5$ — Not prime
- 17 — Prime
- 53 — Prime
- **Exactly 3 primes: 23, 17, 53**

FLAG: thm{23,82,20,17,53}

7. Incident Summary

Phase	Details
Initial Access	Phishing email from <code>billing@westteck-payments.com</code> with malicious <code>.scr</code> attachment
Execution	User opened <code>invoice_payload.scr</code> , running a bash dropper that overwrote itself
Persistence	C2 beaconing via <code>MalwarePing</code> alerts, port scanning for lateral movement
Collection	USB insertions for data staging, encrypted zip creation
Exfiltration	Netcat (<code>/bin/nc</code>) on port 4444 to <code>144.76.12.34</code> , 181,923 bytes sent
Impact	Theft of classified project data (Project Chimera, Vault-Tek intel, prototype designs)

8. Remediation Recommendations

- **Email Security:** Implement DMARC/DKIM/SPF to detect spoofed sender domains
- **Attachment Filtering:** Block `.scr` files at the email gateway
- **Network Monitoring:** Detect and block unauthorized outbound connections on non-standard ports (4444)
- **USB Policy:** Restrict USB device usage via endpoint protection
- **User Training:** Security awareness training for phishing recognition
- **Incident Response:** Automate containment when exfiltration alerts trigger